

MEDSECURE SAS · HEALTHTECH · SAAS · HEALTH DATA

Information Security Management System

ISMS Scope: Clause 5.3

Document ID	SMSI-MDS-C5-002
Version	1.0 : DRAFT
Date	May 2026
Author	Junior Abakar : GRC Consultant
Approved By	CEO : MedSecure SAS (TBD)
Review Frequency	Annual
Next Review	May 2027
Classification	CONFIDENTIAL: For internal use only

This document is provided for informational and educational purposes only as part of a personal GRC portfolio project. It does not constitute professional advice. MedSecure SAS is an entirely fictional organisation; any resemblance to a real entity is coincidental.

Part II · Clause 5.3 ISMS Roles & Responsibilities

I Purpose

This document defines and assigns the roles and responsibilities necessary for the effective implementation, maintenance, and continual improvement of **MedSecure SAS's Information Security Management System (ISMS)** in accordance with **ISO/IEC 27001:2022 Clause 5.3**.

Scope of this document: the responsibilities described here are exclusively those related to the ISMS. They do not constitute exhaustive job descriptions. An individual may hold broader responsibilities in their daily role; only those with a direct bearing on the ISMS are documented here.

II Scope

This document applies to all personnel and functions within the ISMS scope, covering individuals directly responsible for or contributing to the security of information assets and operations associated with MedSecure SAS's cloud-based SaaS patient records management platform (AWS eu-west-3, Paris headquarters, Lyon office, and remote workers).

III Key Roles & Responsibilities

Role	Type	ISMS Responsibilities
Chief Executive Officer CEO	Accountable	- Has overall accountability for the ISMS. - Ensures alignment of the ISMS with strategic business objectives. - Provides necessary resources for ISMS implementation and maintenance. - Approves the Information Security Policy and key ISMS decisions.
Information Security Manager CISO	Responsible	- Leads the implementation and maintenance of the ISMS. - Oversees risk management, control implementation, audits, and improvement activities. - Ensures ISMS compliance with ISO/IEC 27001:2022, HDS, and NIS 2. - Reports ISMS performance to top management. - Coordinates incident response and internal awareness programmes.
Cybersecurity GRC Analyst GRC Analyst	Responsible	- Manages governance, risk, and compliance processes. - Develops and maintains ISMS documentation (policies, risk register, SoA, risk treatment plan). - Conducts internal audits and coordinates with external auditors. - Tracks corrective actions and compliance metrics.

Role	Type	ISMS Responsibilities
Information Security Analyst	Contributor	- Monitors security events and alerts (SOC activities). - Supports threat detection, incident handling, and vulnerability management (Annex A.5.24-A.5.28). - Performs day-to-day technical security tasks (log reviews, endpoint monitoring).
IT Infrastructure Engineer	Contributor	- Manages cloud infrastructure security (AWS eu-west-3 configuration, network segmentation, access controls). - Implements technical controls for systems, network, and endpoints. - Supports backup, recovery, and business continuity processes.
Software Development Team	Contributor	- Applies secure coding practices in application development (Annex A.8.25-A.8.34). - Participates in the Secure Software Development Lifecycle (SSDLC). - Addresses vulnerabilities identified during code reviews or scans.
All Employees & Contractors 45 staff	Compliance	- Must adhere to information security policies and procedures. - Are responsible for protecting company and patient information and reporting security incidents. - Participate in annual security awareness training (Annex A.6.3). - Remote staff must comply with additional teleworking security procedures (Annex A.6.7, A.8.1).

IV Authority Delegation

The **CEO delegates day-to-day responsibility** for the ISMS to the **Information Security Manager (CISO)**, who is empowered to direct ISMS operations, implement controls, coordinate audits, and engage with the certification body.

Fundamental distinction: operational *responsibility* is delegated to the CISO; however, overall *accountability* - the obligation to answer to clients, regulatory authorities (CNIL, ANS), and stakeholders - remains with the **CEO**. This distinction is explicitly required by ISO/IEC 27001:2022 Clause 5.3.

All role holders must operate within their defined authority and escalate security concerns to the appropriate level without delay.

V Communication of Roles

ISMS roles and responsibilities are:

- **Communicated individually** to each relevant staff member by the CISO upon onboarding or whenever this document is updated;
- **Documented** in this document and retained within the ISMS document management system;

- **Reviewed annually** or upon any organisational change (new hire, departure, role change).

VI Approval - Part II

Role	Name	Date	Signature
Author	Junior Abakar - GRC Analyst	May 2026	_____
Reviewer	CISO - MedSecure SAS	TBD	_____
Approved By	CEO - MedSecure SAS	TBD	_____